

Relazione tecnica DVWA e Burp Suite

D'Angelo Giovanni

1. Introduzione

Nel corso dell'esercitazione ho configurato in ambiente Kali Linux la piattaforma DVWA (Damn Vulnerable Web Application) e ho verificato il funzionamento dell'applicazione tramite Burp Suite, seguendo il flusso previsto dalla traccia: preparazione del sistema, configurazione del database MySQL/MariaDB, attivazione del web server Apache, inizializzazione del database DVWA e analisi della richiesta di login con il proxy HTTP.

L'obiettivo pratico dell'attività era arrivare ad una installazione funzionante della web application e, successivamente, utilizzare Burp Suite per intercettare la richiesta HTTP di autenticazione, modificarne i parametri e osservare il comportamento della risposta restituita dal server.

2. Prima prova non conclusa correttamente

Nel primo tentativo ho avviato regolarmente l'ambiente di lavoro e ho iniziato la procedura di configurazione. Sono arrivato fino alla parte di utilizzo di Burp Suite, ma il flusso finale non si è chiuso nel modo richiesto dall'esercizio. In particolare, la parte di verifica pratica tra browser e proxy non ha prodotto una sequenza ordinata e completa come prevista nelle slide, quindi ho considerato la prima prova non pienamente riuscita.

Per questo motivo ho deciso di ripetere l'attività dall'inizio in una seconda sessione, mantenendo gli stessi passaggi ma controllando con maggiore attenzione sia la configurazione dei servizi sia la parte finale di intercettazione e analisi della richiesta HTTP.

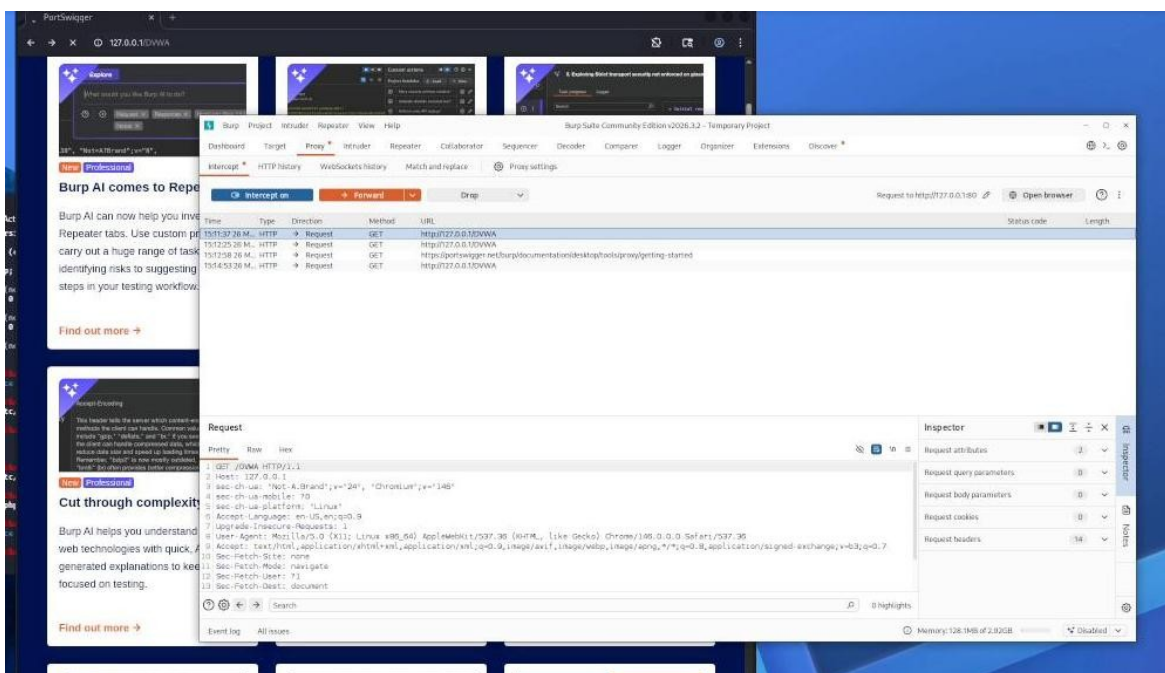


Figura 1 - Prima prova: apertura di Burp Suite durante il primo tentativo, senza completamento del flusso finale richiesto.

3. Seconda prova eseguita correttamente

3.1 Preparazione dell'ambiente e clonazione di DVWA

Nella seconda prova ho ripetuto la procedura in modo completo. Dopo aver aperto il terminale di Kali Linux, sono passato all'utenza amministrativa con `sudo su` e mi sono spostato nella directory `/var/www/html`. Da questa posizione ho clonato il repository DVWA con `git clone`, ho assegnato i permessi ricorsivi alla cartella dell'applicazione con `chmod -R 777 DVWA/` e sono entrato nella directory di configurazione `/var/www/html/DVWA/config`.

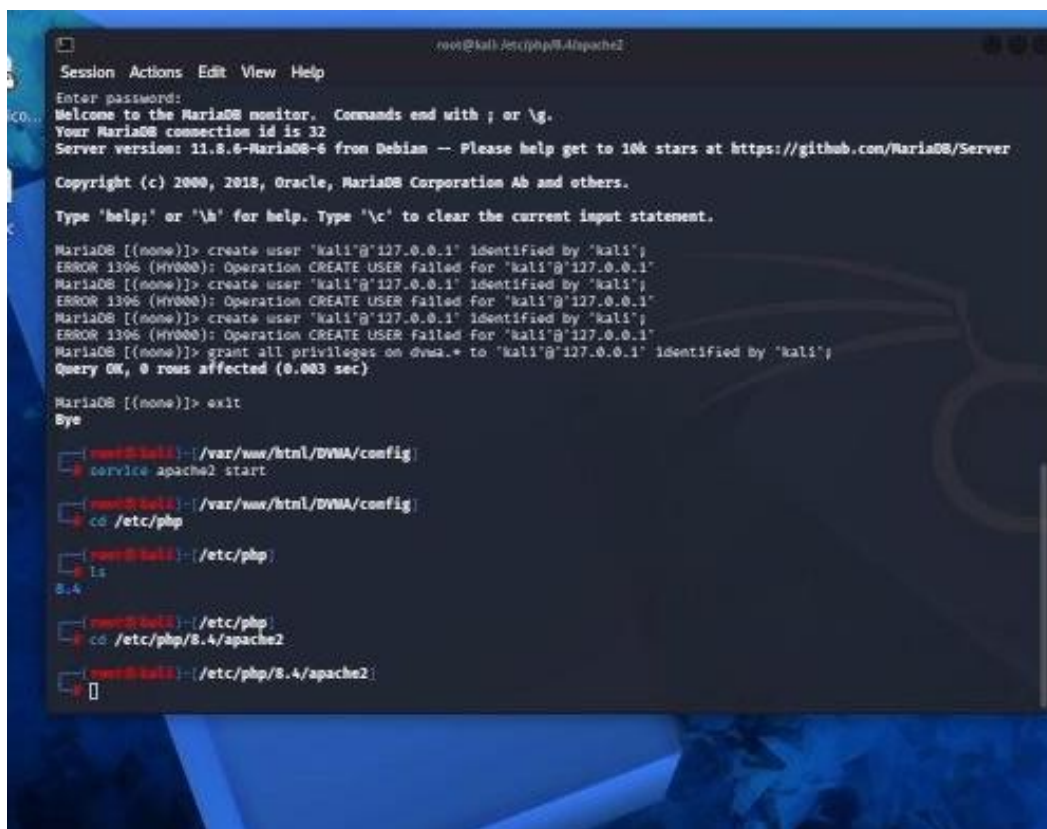
All'interno della cartella config ho copiato il file `config.inc.php.dist` in `config.inc.php` e ho aperto il file di configurazione con `nano`. In questa fase ho impostato come credenziali del database l'utente kali e la password kali, in modo da allineare il file di configurazione della web application ai dati che sarebbero stati utilizzati lato database.

3.2 Configurazione del database MySQL/MariaDB

Terminata la configurazione iniziale dell'applicazione, ho avviato il servizio MySQL/MariaDB con il comando `service mysql start` e mi sono collegato al database come utente root tramite `mysql -u root -p`, inserendo la password prevista.

All'interno della console MariaDB ho eseguito il comando di creazione dell'utente kali associato all'indirizzo 127.0.0.1. Nel corso della seconda prova ho riscontrato che la creazione dell'utente restituiva un errore, perché l'account risultava già presente a seguito dei tentativi precedenti. Ho quindi proseguito con l'assegnazione dei privilegi all'utente kali sul database dvwa mediante `grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali';`. L'assegnazione dei privilegi è andata a buon fine, permettendomi di continuare la configurazione senza blocchi.

Una volta completata la parte database, sono uscito dalla console MariaDB con il comando exit e sono tornato al terminale di sistema.



```
root@kali:~/etc/php/8.4/apache2

Session Actions Edit View Help
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 32
Server version: 11.8.6-MariaDB-6 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create user 'kali'@'127.0.0.1' identified by 'kali';
ERROR 1306 (HY000): Operation CREATE USER failed for 'kali'@'127.0.0.1'
MariaDB [(none)]> create user 'kali'@'127.0.0.1' identified by 'kali';
ERROR 1306 (HY000): Operation CREATE USER failed for 'kali'@'127.0.0.1'
MariaDB [(none)]> create user 'kali'@'127.0.0.1' identified by 'kali';
ERROR 1306 (HY000): Operation CREATE USER failed for 'kali'@'127.0.0.1'
MariaDB [(none)]> grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali';
Query OK, 0 rows affected (0.003 sec)

MariaDB [(none)]> exit
Bye

root@kali:~/etc/php/8.4/apache2# service apache2 start
root@kali:~/etc/php/8.4/apache2# cd /etc/php
root@kali:~/etc/php# ls
8.4
root@kali:~/etc/php# cd /etc/php/8.4/apache2
root@kali:~/etc/php/8.4/apache2#
```

Figura 2 - Configurazione del database e verifica del percorso PHP utilizzato nella seconda prova.

3.3 Configurazione di Apache e di PHP

Dopo aver configurato il database, ho avviato il web server con `service apache2 start`. Successivamente mi sono spostato nella directory `/etc/php` per verificare la versione di PHP presente nel sistema. A differenza dell'esempio riportato nelle slide con il percorso `/etc/php/8.1/apache2`, nel mio ambiente risultava installata la versione 8.4, per cui ho continuato la procedura nella directory `/etc/php/8.4/apache2`.

Da questa posizione ho aperto il file `php.ini` e ho modificato i parametri `allow_url_fopen` e `allow_url_include`, impostandoli su `On`, come richiesto per il corretto funzionamento dell'ambiente DVWA. Terminata la modifica del file, ho riavviato nuovamente Apache per applicare le impostazioni aggiornate.

3.4 Inizializzazione del database DVWA e accesso all'applicazione

A configurazione terminata ho aperto il browser e ho raggiunto l'indirizzo `127.0.0.1/DVWA/setup.php`. Dalla pagina di setup ho eseguito il comando `Create / Reset Database`, così da inizializzare correttamente il database dell'applicazione.

Conclusa questa fase, il sistema mi ha reindirizzato alla schermata di login di DVWA. Ho effettuato l'accesso con le credenziali di default `admin` come username e `password` come password. Una volta entrato nella piattaforma, ho aperto la sezione DVWA Security e ho impostato il livello di sicurezza su `low`, salvando la modifica. In questo modo ho allineato l'applicazione allo scenario operativo previsto dall'esercitazione.

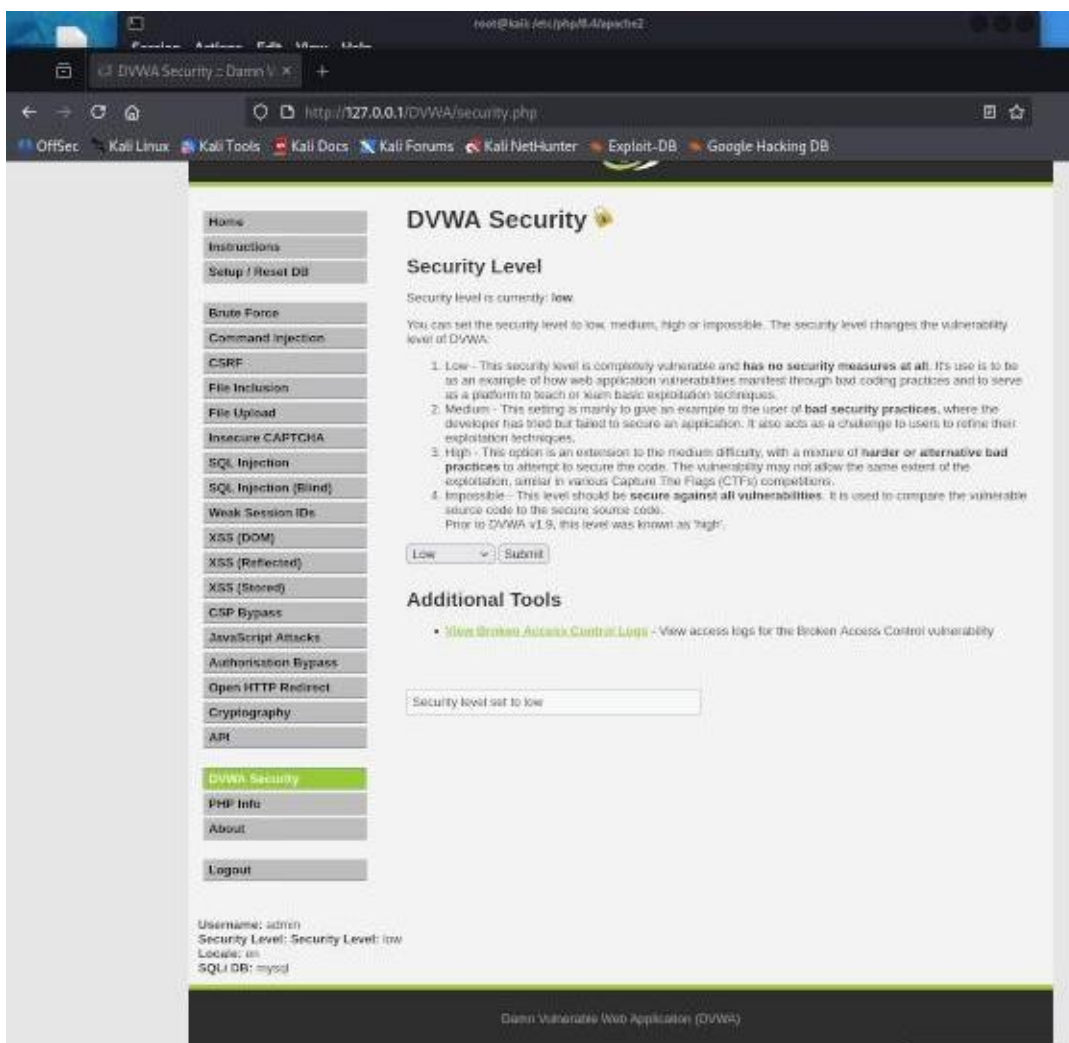


Figura 3 - DVWA configurata correttamente con livello di sicurezza impostato su low.

3.5 Utilizzo di Burp Suite e analisi della richiesta di login

Dopo aver verificato il corretto avvio di DVWA, ho aperto Burp Suite scegliendo un progetto temporaneo. Ho quindi lavorato nella sezione Proxy, attivando l'intercettazione delle richieste HTTP provenienti dal browser.

A questo punto ho raggiunto la pagina di login dell'applicazione e ho lasciato che Burp intercettasse la richiesta relativa all'autenticazione. Dopo la cattura della richiesta, l'ho inoltrata nell'area Repeater per poterla analizzare e modificare con maggiore precisione.

Nel pannello Repeater ho esaminato la richiesta POST verso /DVWA/login.php, verificando i parametri inviati nel body della richiesta. Come previsto dalla traccia, ho modificato manualmente i campi di autenticazione inserendo credenziali intenzionalmente errate. Ho quindi inviato la richiesta modificata con il pulsante Send e ho seguito la risposta del server tramite l'opzione Follow redirection.

La prova ha confermato il comportamento atteso: il server ha gestito la richiesta alterata senza concedere un accesso valido, restituendo il comportamento coerente con un tentativo di login non corretto. In questo modo ho completato correttamente la parte di osservazione e manipolazione della richiesta HTTP tramite Burp Suite.

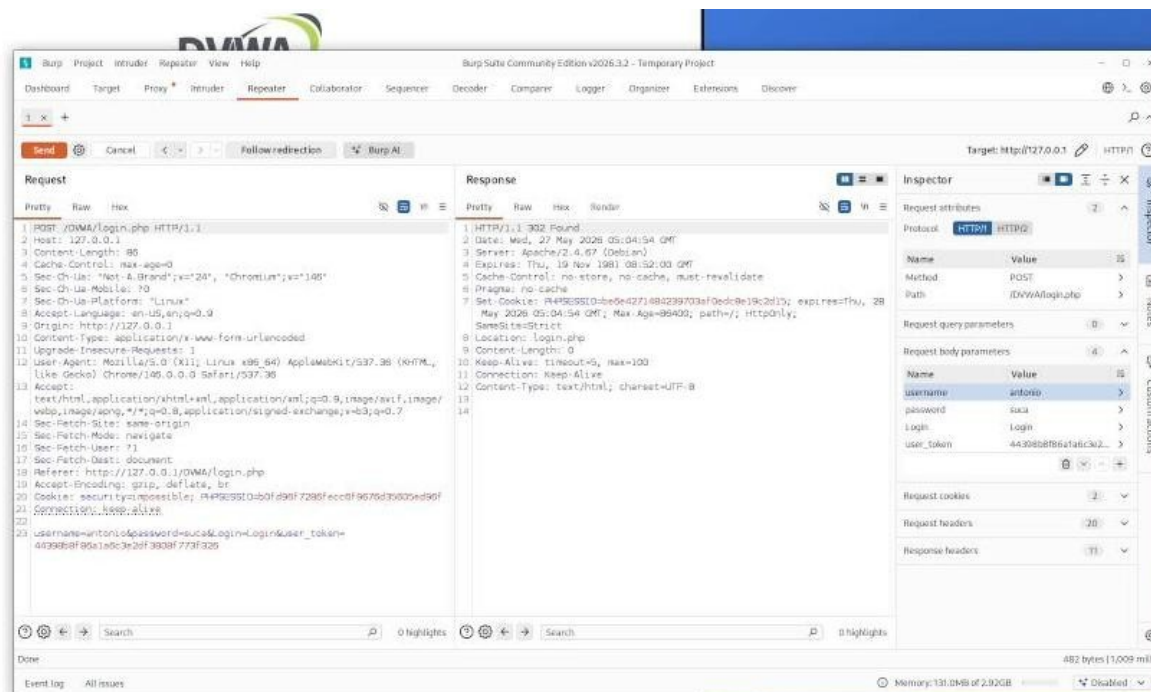


Figura 4 - Analisi della richiesta di login in Burp Repeater con parametri modificati e verifica della risposta HTTP.

4. Considerazioni tecniche

L'esercitazione ha evidenziato alcuni aspetti pratici importanti. Il primo è che un ambiente di test come DVWA richiede una configurazione coerente tra file applicativi, database e servizi web: basta una credenziale non allineata o un parametro PHP non corretto per impedire il funzionamento dell'applicazione.

Il secondo aspetto è legato alla differenza tra teoria e ambiente reale. Le slide indicavano un percorso PHP riferito alla versione 8.1, mentre nel mio sistema la versione presente era 8.4. È stato quindi necessario adattare il percorso in modo corretto senza alterare la logica della procedura.

Un ulteriore elemento emerso durante la prova è la gestione degli errori dovuti a stati preesistenti del sistema. Il messaggio relativo all'utente già esistente in MariaDB non ha impedito la prosecuzione dell'esercizio, ma ha richiesto una lettura corretta del contesto per capire che il problema non riguardava i privilegi, che infatti sono stati assegnati con successo.

5. Conclusioni

Nel complesso ho completato con successo la seconda esecuzione dell'esercizio, arrivando ad una DVWA funzionante, accessibile da browser locale e configurata con livello di sicurezza low, oltre ad una verifica pratica del traffico HTTP tramite Burp Suite.

La presenza di una prima prova non riuscita è stata utile per correggere il flusso operativo e ripetere l'attività in modo più rigoroso. La seconda prova mi ha permesso di chiudere correttamente sia la parte infrastrutturale, relativa a database e web server, sia la parte applicativa e di analisi, relativa all'intercettazione e modifica della richiesta di login.